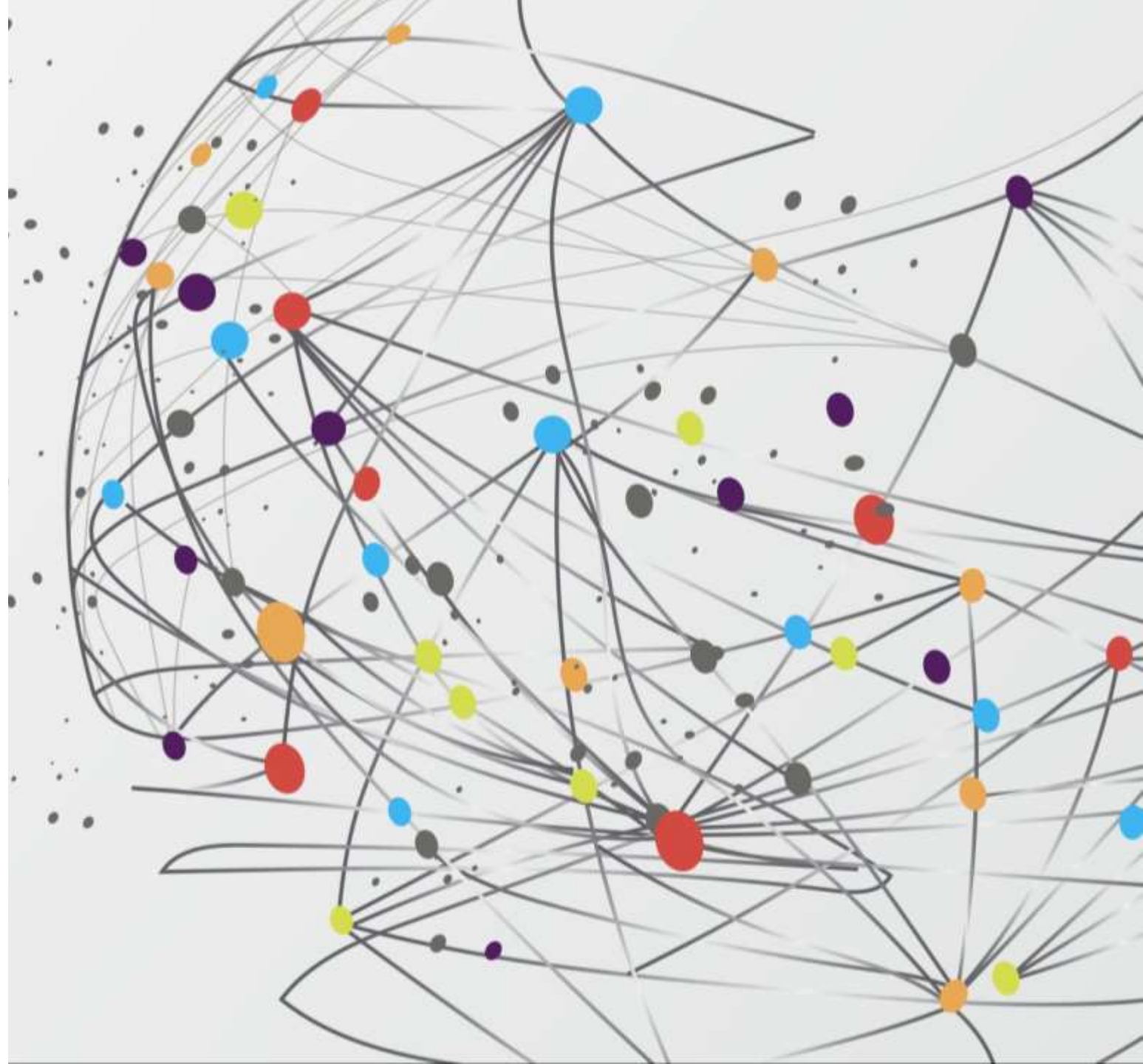

SİBER GÜVENLİĞE GİRİŞ

BÖLÜM 12 CYBERSECURITY STANDARTS

Dr. Öğr. Üyesi Ahmet Kaşif

ahmet.kasif@btu.edu.tr



12.1 INTRODUCTION

12.1.1 THE IMPORTANCE OF STANDARDS IN CYBERSECURITY

Definition: Standards are defined guidelines and best practices.

Purpose: To achieve specific objectives within an industry.

Chapter Focus: Exploring key cybersecurity standards in ICT.

12.1.2 THE DEVELOPMENT AND SCOPE OF CYBERSECURITY STANDARDS

Standard Development: Created by standard organizations, industry alliances, and government authorities. Based on deep research with industry experts.

Areas Covered by Standards:

- Security of web environment code.
 - Criteria for computer code testing.
 - Assessment of web environment vulnerabilities.
 - Impact of vulnerabilities.
-

-
- Ways to prevent security threats.
 - Risk assessment.
 - Secure communication implementation.
 - Handling potential threats.
 - Preemptive cyber threat measures.

Overall Goal: To identify the most suitable ways and best practices for effective cybersecurity.

12.1.3 THE IMPACT AND IMPLEMENTATION OF CYBERSECURITY STANDARDS

Detailed Documentation: Standards include detailed documents establishing relationships between different security guidelines.

Implementation Framework: Defines scope of work, roles, implementation procedures, and audit processes for smooth adoption.

Global Acceptance (Example: ISO): International standards like those from ISO are accepted worldwide, allowing organizations globally to establish information security controls.

- **Next Steps:** The chapter will now discuss specific, commonly adopted cybersecurity standards in the ICT field.
-

12.2 ISO/IEC 27001 & 27002 STANDARDS

12.2.1 ISO/IEC 27001 & 27002: THE CORNERSTONES OF IT SECURITY CONTROL

Focus: Information technology control within IT organizations.

Developer: International Organization for Standardization (ISO).

Common Designation: ISO 2700X.

12.2.2 OBJECTIVES OF THE ISO 27000 SERIES

Key Objectives:

- Establishing information security controls.
 - Reducing security risks.
 - Streamlining cybersecurity procedures.
 - Selection of appropriate security controls.
 - Management of implemented security controls.
 - Implementation and ongoing monitoring of security controls.
-

12.2.3 EMPOWERING ORGANIZATIONS WITH ISO 27000

Steps Enabled for Companies:

- **Choosing Right Controls:** Select information security controls aligned with recommendations.
- **Implementing Proven Controls:** Adopt established and effective IT controls used across industries.
- **Developing Compliant Controls:** Create new controls that meet ISO criteria and organizational needs.

Continuous Improvement: The standards are regularly updated to address evolving security threats and risks.

12.2.4 ACHIEVING ISO 27000 CERTIFICATION

Certification Process: ISO offers certifications upon successful implementation and regular audits.

Cost of Compliance: Accessing detailed requirements and achieving certification involves fees.

Consultant Support: ISO has a network of consultant companies worldwide to assist organizations with implementation.

Annual Audits: Organizations typically undergo annual security audits to ensure ongoing compliance with established procedures (SOPs).

- **Broader Governance:** These standards align with other cybersecurity governance frameworks offered by ISO.
-

12.3 INFORMATION SECURITY

12.3.1 INTRODUCING THE INFORMATION SECURITY FORUM (ISF)

Focus: Providing insights into existing and emerging security threats.

Approach: Devising good practices for risk management in IT security.

Target Audience: Organizations seeking to improve their security posture.

12.3.2 KEY AREAS COVERED BY ISF GOOD PRACTICES

Major Areas of Focus:

- Risks associated with Agile software development.
 - Privacy of information and intelligence on emerging threats.
 - Security aspects of Industrial Control Systems (ICSs).
 - Assessing the relationship between operational risk and information risk.
-

12.3.3 BENEFITS OF ADOPTING ISF GOOD PRACTICES

Organizational Advantages:

- **Exploiting New Opportunities:** Helps leaders and teams improve productivity and efficiency while maintaining strong security against information risks.
- **Proactive Threat Management:** Prepares organizations to anticipate potential threats and reduce risk through agility and preparedness.
- **Efficient Implementation:** Identifies effective and efficient ways to implement security standards.

Overall Impact: Improves the efficiency, agility, and effectiveness of security personnel and organizational leaders by fostering alertness and innovative thinking.

- **Business Focus:** ISF's approach is primarily business-driven.
-

12.4 PAYMENT CARD INDUSTRY DATA

12.4.1 PROTECTING PAYMENT CARD INFORMATION: THE PCI DSS

Developer: Developed by the PCI Security Standards Council.

Primary Goal: To safeguard bank and card information used for online shopping.

Global Impact: Directly affects millions of card users worldwide.

12.4.2 THE DRIVING FORCES BEHIND PCI DSS

Council Members:

- American Express
 - MasterCard Inc.
 - Visa Inc.
 - JCB International
 - Discover Inc.
-

12.4.3 TARGET ORGANIZATIONS FOR PCI DSS COMPLIANCE

Target Organizations:

- Point-of-Sales (POS) manufacturers
 - Financial software developers
 - Financial hardware developers
 - Merchants of all sizes
 - Financial institutes/banks
-

12.4.4 HOW PCI DSS ACHIEVES CARD INFORMATION SECURITY

Key Functions:

- **Implementing Security Measures:** Establishes security-related technology, policies, and best practices for current and future financial processes at merchant and financial institution levels.
 - **Guiding Vendors:** Helps hardware and software vendors integrate security features and capabilities into their products during development.
 - **Current Adoption:** Almost all financial institutions and merchants currently implement and adhere to PCI DSS guidelines and standards.
-